1.DAY 32 — AUTHENTICATION & ACCOUNT SECURITY

Web Application Security | Lab Assignment Report

1.1 Part A — Authentication Fundamentals

Q1. Explain authentication in your own words. Give two examples of authentication factors.

Authentication is the process of verifying that a person or system is really the identity it claims to be before access is granted. It answers the question, “Who are you?” Common authentication factors include something you know, such as a password or PIN, and something you have, such as an authenticator-app code or security key. A third factor is something you are, such as a fingerprint or face biometric.

Q2. Explain the difference between authentication and authorization using one practical example.

Authentication verifies identity, while authorization decides what that verified identity is allowed to access or perform. For example, when a student logs into the Jayvik Labs Student Portal, the password/MFA process authenticates the student. After login, authorization determines whether that student can view their own marks but prevents them from editing another student’s marks or opening an administrator-only panel.

1.2 Part B — Username Enumeration & Credential Attacks

Q3. Explain username enumeration. Give two examples of application behavior that could reveal whether a username exists.

Username enumeration occurs when an application unintentionally allows someone to determine whether a particular username or account exists. This can help attackers identify valid accounts for later attacks. One example is a login form returning different messages such as “username not found” versus “incorrect password.” Another example is a password-reset page showing different responses, timing, or account-recovery options for an existing account compared with a non-existing account. Secure applications should use consistent responses and avoid exposing account existence.

Q4. Explain: (a) Brute-force attack (b) Credential stuffing. Mention one important difference.

(a) Brute-force: systematically trying many possible passwords or authentication combinations against an account. (b) Credential stuffing: using previously leaked username/password pairs from another service and testing whether users reused those credentials. The key difference is that brute force attempts to discover credentials, whereas credential stuffing relies on credentials already obtained elsewhere. Rate limiting, MFA, strong passwords, and detection controls help reduce both risks.

Authentication Security Summary

Authentication: verifies identity. Authorization: controls permitted actions.
Enumeration risk: inconsistent messages, timing, or recovery behavior can reveal account existence.
Credential attacks: rate limiting, MFA, monitoring, and secure password practices reduce attack success.

1.3 Part C — Authentication Defenses

Q5. Explain how Rate limiting, MFA, and generic login error messages improve authentication security.

Rate limiting restricts repeated login attempts and slows automated password guessing and credential-stuffing activity. MFA adds another authentication factor, so a stolen password alone is not sufficient to access the account. Generic login errors use a consistent response such as “Invalid username or password” instead of revealing which part was incorrect. This reduces username enumeration and makes account discovery harder. Together, these controls reduce both automated attacks and information leakage.

1.4 Part D — Password Reset

Q6. Describe at least four properties of a secure password-reset mechanism.

A secure password-reset mechanism should use cryptographically strong, unpredictable reset tokens; tokens should be short-lived and single-use; reset links should be delivered only through a verified recovery channel; and the application should apply rate limiting to reset requests and token attempts. The system should avoid revealing whether an account exists, should invalidate the token after successful use, and should not expose passwords or reset tokens in logs or normal application responses.

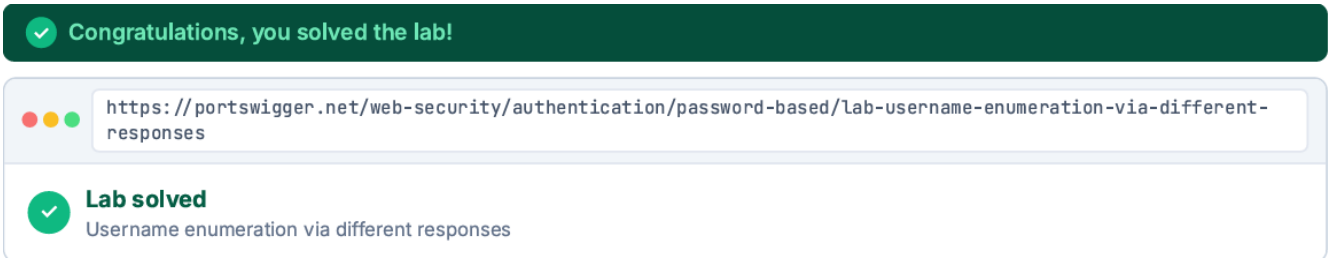
1.5 Part E — Practical Lab

Q7. Include evidence from the Day 32 PortSwigger authentication lab. Explain the relevant authentication weakness, what vulnerability was observed, how the application leaked information, and how it should be mitigated.

The relevant authentication weakness is username enumeration. An application can leak information when its responses differ depending on whether an account exists—for example, through different error messages, response behavior, timing, or password-reset responses. This information can help an attacker identify valid usernames. Mitigation includes consistent authentication and recovery responses, avoiding account-existence disclosures, applying rate limits, using MFA, monitoring suspicious authentication activity, and securing password-reset workflows.

Evidence to add: Insert one screenshot from your own Day 32 PortSwigger lab showing the relevant result. Do not include passwords, session cookies, tokens, or other sensitive information.

Screenshot:



1.6 Part F — Secure Login Design

Q8. Imagine you are securing the Jayvik Labs Student Portal. Recommend at least five controls for its login/account authentication system.

1. MFA: require an additional factor for higher-risk accounts or sensitive actions.
2. Rate limiting and lockout controls: slow repeated authentication attempts without creating an easy denial-of-service condition.
3. Generic authentication errors: use consistent responses to reduce username enumeration.
4. Secure password storage: store passwords using a modern password-hashing algorithm with unique salts; never store plaintext passwords.
5. Secure session management: use secure, HttpOnly and appropriately scoped cookies, session expiration, and session rotation after authentication.
6. Password-reset protection: use unpredictable, short-lived, single-use reset tokens and avoid revealing account existence.
7. Monitoring and logging: detect suspicious login patterns while protecting sensitive authentication data in logs.

Authentication Control Matrix

Control	Security Purpose	Jayvik Portal Application
MFA	Reduces impact of stolen passwords	Protect student/admin accounts and sensitive actions
Rate limiting	Slows automated login attacks	Limit repeated login and reset requests
Generic errors	Reduces username enumeration	Use the same safe response for invalid credentials
Secure password hashing	Protects stored passwords if the database is exposed	Use a modern adaptive password-hashing scheme with unique salts
Secure sessions	Reduces session theft and	Use Secure/HttpOnly

	misuse	cookies, appropriate expiration and session rotation
Protected reset flow	Prevents reset-token abuse	Use short-lived, single-use, unpredictable tokens with consistent responses

Final Security Summary

A secure authentication system must verify identity without unnecessarily revealing account information. Authentication and authorization should remain separate: successful login does not automatically grant every permission. Username enumeration should be prevented with consistent responses, while brute-force and credential-stuffing risks should be reduced through rate limiting, MFA, strong password practices, and monitoring. Password-reset tokens must be unpredictable, short-lived, and single-use. For the Jayvik Labs Student Portal, these controls should be enforced server-side and supported by secure session management, logging, and safe error handling.